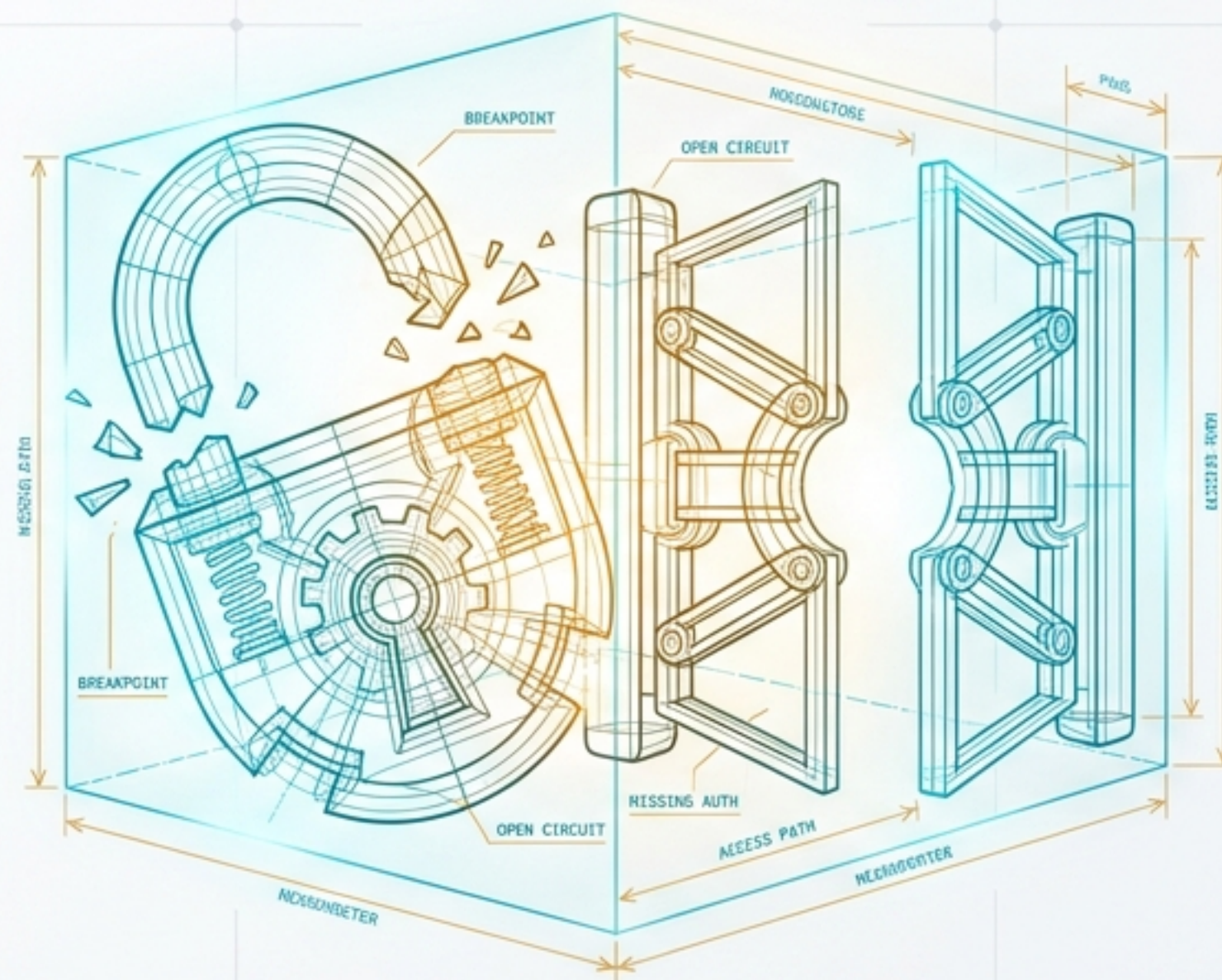


Diagnostic Report: CVE-2026-9008

Anatomy of the Page-list Missing Authorization Vulnerability



Target: WordPress Page-list Plugin | Severity: Medium | Access Vector: Network

Threat Snapshot of the Page-list Plugin



The Target

Vendor: webvitaly

Plugin: Page-list

Affected Versions: <= 6.2

Vulnerability: Missing
Authorization (CWE-862)



The Vector

Authentication: Required
(Minimum Role:
Contributor)

User Interaction: None

AV:N

AC:L

UI:N

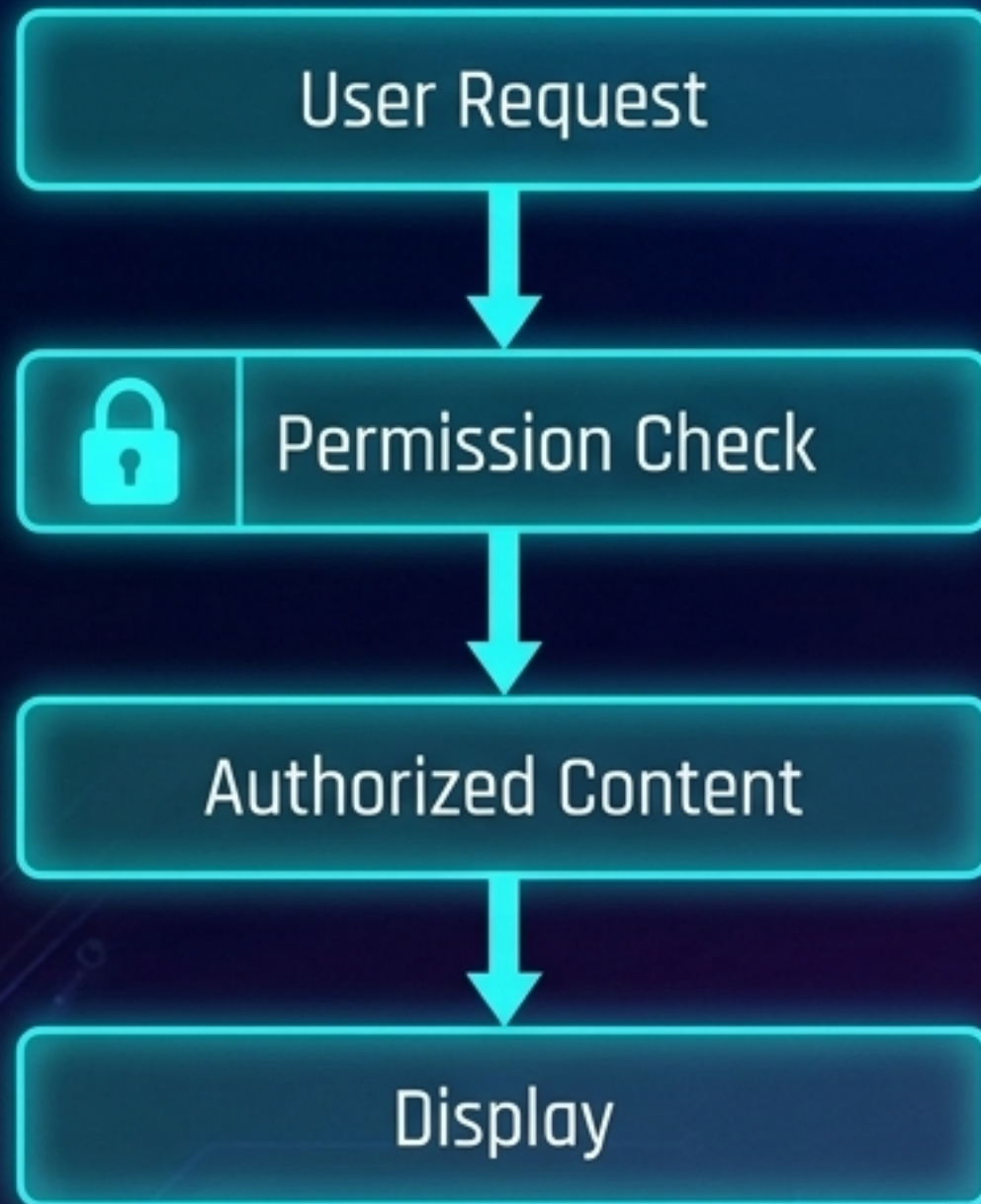
PR:L

CVSS 3.1 Score

4.3 (Medium)

The Architecture of a Missing Authorization Check

Normal Secure Flow



Vulnerable Flow



Unfiltered Shortcodes Become Direct Database Queries

Function: `pagelist_unq_prfx_ext_shortcode()`

Vulnerable Shortcodes: `[pagelist_ext]` and `[pagelistext]`

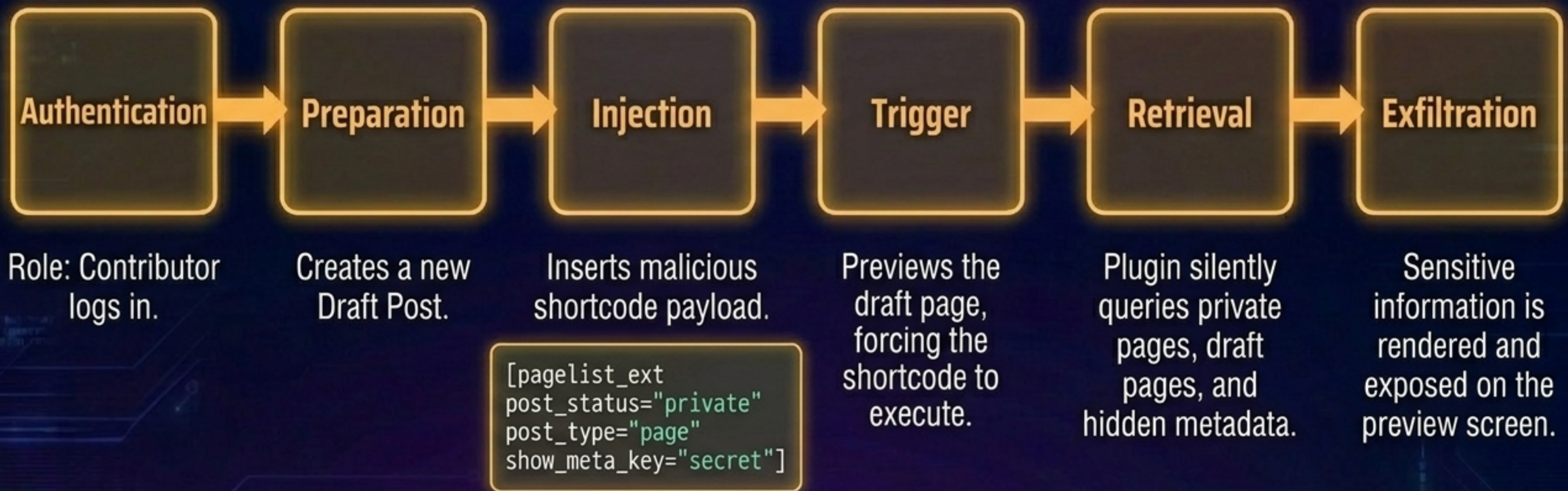
Input Vector

Attacker-controlled attributes (`post_status`, `post_type`, `show_meta_key`) are accepted natively.

Execution Failure

These specific attributes are passed directly into WordPress core functions `get_pages()` and `get_post_meta()` with zero authorization validation.

The Contributor-to-Exfiltration Attack Chain



A Null Value Expands the Blast Radius

Expected Scope
Only Child Pages

The Logic Flaw

When a current page has no child pages, the plugin executes `child_of => 0`.

This broadens the search entirely. Instead of restricting queries to local child pages, the scope defaults to all matching pages, exponentially increasing data exposure.

Actual Scope
All Pages Matching Query

Categorizing the Exposed Organizational Data



Editorial Assets

- Private Page Names
- Confidential Content
- Unpublished Draft Material



Technical Secrets

- Hidden Custom Fields
- Stored API Keys
- Internal Settings and Configurations



Business Intelligence

- Internal Documentation
- Workflow Information
- Customer Data stored in private notes

Threat Mapping and Technical Impact Assessment

MITRE ATT&CK Mapping

T1078: Valid Accounts (Leverages legitimate Contributor credentials).

T1213: Data from Information Repositories (Discloses private WordPress content).

T1005: Data from Local System (Exposes sensitive page information).

CIA Triad Impact

Confidentiality: EXPOSED (Risk: High due to internal content disclosure)



Integrity: NOT IMPACTED



Availability: NOT IMPACTED



Conclusion: Overall risk remains Medium because exploitation is trivial and requires only base-level Contributor access.

Telemetry and Detection Vectors

WordPress Application Logs

Monitor for:

Spikes in Draft Previews by lower-tier users.

Anomalous Contributor activity.

Execution of [pagelist_ext] shortcodes accessing unexpected metadata.

WAF Detection Rules

Look for payloads containing:

```
post_status=private
```

```
show_meta_key=
```

Note: Flag these strings particularly when routed through WP preview endpoints.

Restoring the Authorization Gate

Vulnerable State

```
allow_access(); ⚠
```

Secured State

```
if(current_user_can('read_private_pages')) ✓  
{  
    allow_access();  
}  
else  
{  
    deny_access();  
}
```

Key Insight: Implementing `current_user_can()` enforces native WordPress role-based access control before any data retrieval occurs.

Tactical Mitigation and Perimeter Defense

Step 1: Patch

Upgrade the Page-list plugin to a secure version immediately upon release.

Step 2: Disable

Temporarily disable the vulnerable `[pagelist_ext]` shortcode if patching is not immediately feasible.

Step 3: Restrict

Audit and restrict Contributor access across the WordPress environment.

Step 4: Audit

Review all private pages and stored metadata to ensure no critical business data or API keys are unnecessarily stored in WordPress.

Secure the perimeter. Verify the access.